PayU Finshield v5.0: Policy Draft, Process Flow & Business Model

Supporting dossier · IIM Bangalore × PayU Fintech Challenge 2026 · Universal Anti-Laundering & Dynamic Liquidity Guard

Nov 11, 2026 · @Sumit & @Kritika

1. At a glance

The problem. A genuine neighbourhood business can be turned into a laundering channel overnight. In our reference case, The Daily Crumb Bakery in Indiranagar, Bengaluru takes about ₹25,000 a day in real orders. At 11:30 PM the same merchant ID carries ₹4,25,000 of masked betting traffic from sportsbook bots, crash-game APKs and offshore casino WebViews. Freezing the account bankrupts a real MSME; ignoring the traffic exposes PayU to RBI anti-money-laundering penalties and NPCI chargeback fines.

The answer. Finshield never freezes an account. It forks the merchant's liquidity transaction by transaction. Normal working capital settles on T+1 (Track A). Only the surge is held, in a 48-hour escrow (Track B), until GSTN e-invoice data proves it is genuine. Four independent signals, scored 0–100 before settlement, decide where each rupee goes.

Problem	Finshield's answer	Proof in the prototype
One merchant ID carries both legitimate and illegal volume	Fork liquidity per transaction instead of freezing the account	Attack day: ₹25,000 settles T+1, ₹4,00,000 is held in escrow
Legacy checks watch the wrong layer: referrers, devices, inflow only, PDF invoices	Four fused signals: origin, geographic spread, payout fan-out, disputes	Scores of 12, 34 and 91 across the three scenarios
RBI and NPCI exposure	T+0 escrow, payout circuit-breaker and GSTN-based clearance	A 4.82% dispute wave against the 1.00% NPCI ceiling is quarantined before payouts disperse

Headline metric	Result	Why it matters
Checkout overhead	Under 15 ms (10.4 ms and 11.8 ms in the sandbox)	Genuine UPI conversion never waits
External cost on baseline volume	About ₹0 on about 98% of volume	Signals run in-house on Kafka and Redis
Statutory audit cost	About ₹1.50 per GSTN pull against about ₹45 per manual case, roughly 97% lower	Compliance spend falls sharply
False-positive churn	Near zero	Track A always settles, so genuine merchants stay

How this dossier is organised. Section 4 is the policy (Part A), Section 5 the process flow (Part B) and Section 6 the business model (Part C). Sections 2 and 3 explain the terms and the reference case. Section 7 states the limits honestly and Section 8 closes with the final conclusion.

2. Key terms in plain English

Term	Meaning
Merchant masking	Using a real merchant's payment credentials to route unrelated, illegal volume, here betting
MID	Merchant ID, the identity a merchant uses to accept payments
EMA30D	30-day exponential moving average of daily inflow. It weights recent days more and represents the merchant's normal
+2σ bound	Two standard deviations above the EMA. It is the ceiling of normal volume (₹28,500 for the bakery) and acts as the surge trigger
Track A	Protected base working capital, settled on T+1
Track B	Surge liquidity escrow, a 48-hour T+0 quarantine
HMAC	A cryptographic signature proving a checkout started from the merchant's registered domain or POS, even when the browser referrer is hidden
Shannon entropy (H)	A measure of geographic spread. Low means local footfall, high means nationwide traffic

Term	Meaning
Payout fan-out	Outbound payees per inflow stream. 1 : 2 is a business paying two suppliers; 1 : 214 is a betting app paying winners
RRN	UPI Retrieval Reference Number, the ID used when a payer raises a dispute
GSTN, IRN, GSP	GSTN is the GST network. IRN is the Invoice Reference Number on a government e-invoice. A GSP is an authorised provider of API access to it
STR, FIU-IND	Suspicious Transaction Report, filed with the Financial Intelligence Unit, India

3. The reference case: one merchant, two lives

Attribute	By day: legitimate	By night: masked
Entity	The Daily Crumb Bakery, MCC 5462 (Bakeries), GSTN 29AABCU9603R1ZM, settlement account HDFC •••4091	The same merchant ID used by sportsbooks and crash APKs
Volume	About ₹25,000 a day of sourdough, pastry and coffee orders	₹4,25,000 at 11:30 PM
Digital origin	dailycrumb.in and in-store static QR or POS	Unsigned WebViews: t.me/bet_bot, aviator99.club, royalroulette.io
Tax evidence	B2B invoices from 2–4 verified dairy and flour mills	₹0 of matching B2B inputs against ₹4,25,000 of turnover
Statistical guard	30D EMA ₹24,850 and +2σ bound ₹28,500	₹4,00,000 surge isolated in Track B

4. Part A: Policy draft (SOP-FIN-2026-v5.0)

4.1 Purpose and scope

This policy replaces binary merchant suspension with transaction-level liquidity forking. It applies to high-masking-risk merchant categories, starting with MCC 5462 (Bakeries) and extending to florists, digital goods and EdTech. It closes four legacy blind spots: referrer spoofing (null-referrer tags, Telegram bots, sideloaded APKs), device fingerprinting that sees thousands of real phones instead of one bot farm, money-in-only monitoring that ignores payouts, and forged PDF invoices that pass manual review.

4.2 Policy clauses (draft for approval)

#	Clause	Rationale
1	**No blanket freezes.** Finshield shall not suspend a merchant account on a risk score alone. It acts on liquidity, transaction by transaction	Protects genuine MSMEs, especially in festive peaks
2	**Protected base.** Working capital up to the merchant's normal daily run-rate (₹25,000 in the reference case) shall settle on T+1 in every risk tier, including Red	Wages and supplier bills are paid even during an attack
3	**Surge trigger.** When daily inflow exceeds the merchant's EMA30D + 2σ, the volume beyond the protected base shall go to Track B, a 48-hour T+0 quarantine escrow	A merchant-specific statistical limit, not a one-size-fits-all cap
4	**Statutory evidence only.** Escrow shall be released on a programmatic GSTN e-invoice (IRN) and GSTR-2B match. Uploaded PDF invoices shall not be accepted as proof	Closes the forged-paper-audit blind spot
5	**Payout circuit-breaker.** In the Red tier, outbound payouts shall be locked at T+0	Betting needs instant micro-withdrawals to winners; locking them breaks the cycle
6	**Escalation.** A failed statutory match shall open a case with the Senior Risk Desk (24-hour SLA), trigger Level-2 storefront Video KYC and start FIU-IND STR preparation	A defined regulatory recourse path
7	**Explainability.** Every routing decision shall be logged with its four signal values, score, tier and action	A full audit trail for RBI, NPCI and the sponsor bank
8	**Review.** Thresholds shall be reviewed periodically against false-positive and detection rates	Keeps the policy calibrated

4.3 The four signals

Each signal is built to defeat one way the legacy gateway is blind. Together they produce one composite Dynamic Risk Score from 0 to 100, computed before settlement.

Signal	What it checks	Normal bakery day	Attack	What it defends against
1. HMAC origin binding	Is the checkout session signed for the registered domain or authorised POS bridge?	Valid: dailycrumb.in	Missing: t.me/bet_bot, aviator99.club, 91club-color.apk	Referrer spoofing
2. Spatial entropy and payer novelty	How widely is volume spread across states, and how many payer VPAs are first-timers?	H = 0.19 (91% Karnataka); 14% novel VPAs	H = 0.96 (19 states); 98% novel VPAs	Real-phone traffic that fingerprinting cannot flag
3. Payout fan-out	How many outbound payees does one inflow stream feed?	1 : 2	1 : 214	Money-in-only blindness
4. Dispute and RRN velocity	What share of transactions is disputed, against the NPCI 1.00% ceiling?	0.03%	4.82%	Friendly-fraud chargebacks by losing gamblers

Entropy is calculated as $H = -\Sigma\ p(x_i)\ \log_2\ p(x_i)$, where $p(x_i)$ is the share of volume from state i. The prototype reports it on a 0–1 scale: close to 0 means volume clustered in one place, close to 1 means evenly dispersed. The fourth legacy blind spot, forged paper audits, is closed by the GSTN clearance loop in Section 5.

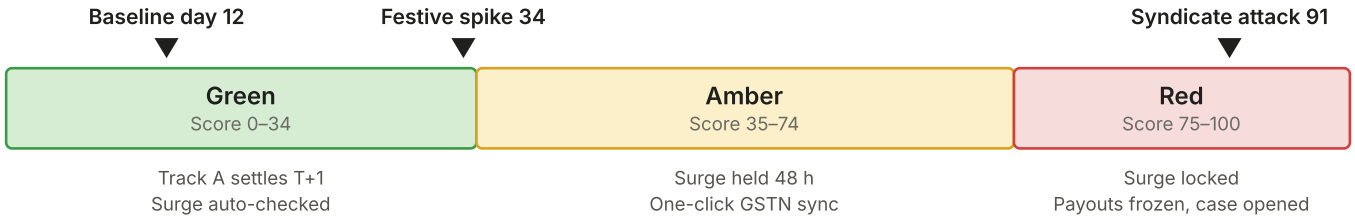
4.4 Risk tiers and governance matrix

Tier and score	Trigger conditions	Liquidity action	Statutory action
Green 0–34	HMAC valid; H ≤ 0.35; fan-out ≤ 1 : 4; disputes below 0.25%	Track A settles T+1. Any surge above the trigger is held briefly for an automatic IRN check	GSTN match in about 1.2 s auto-releases the escrow
Amber 35–74	Partial HMAC match (new subdomain or unlinked POS); H 0.36–0.65; novel VPAs 40–75%	Track A settles T+1; surplus is held in Track B for 48 hours	Merchant prompted for a one-click GSTN sync within 24 hours; no PDF uploads
Red 75–100	HMAC missing; H ≥ 0.75; novel VPAs ≥ 85%; fan-out 1 : 214; disputes 4.82%	₹25,000 base still settles; ₹4,00,000 locked in Track B; payouts frozen at T+0	Case #FIN-8942-RG to the Senior Risk Desk (24-hour SLA), Video KYC, FIU-IND STR prepared

The prototype scores (12, 34 and 91) are taken from the simulation. The other cut-offs are proposed operating targets, to be calibrated in the pilot (Section 7).

Festive spike (34) stays Green; the attack (91) lands deep in Red

Dynamic risk score bands and where the three prototype scenarios land



risk tiers 0–100 · three prototype scenarios. Each prototype scenario lands in a different tier. The 35 and 75 cut-offs are proposed targets for the pilot to calibrate.

4.5 Roles (proposed)

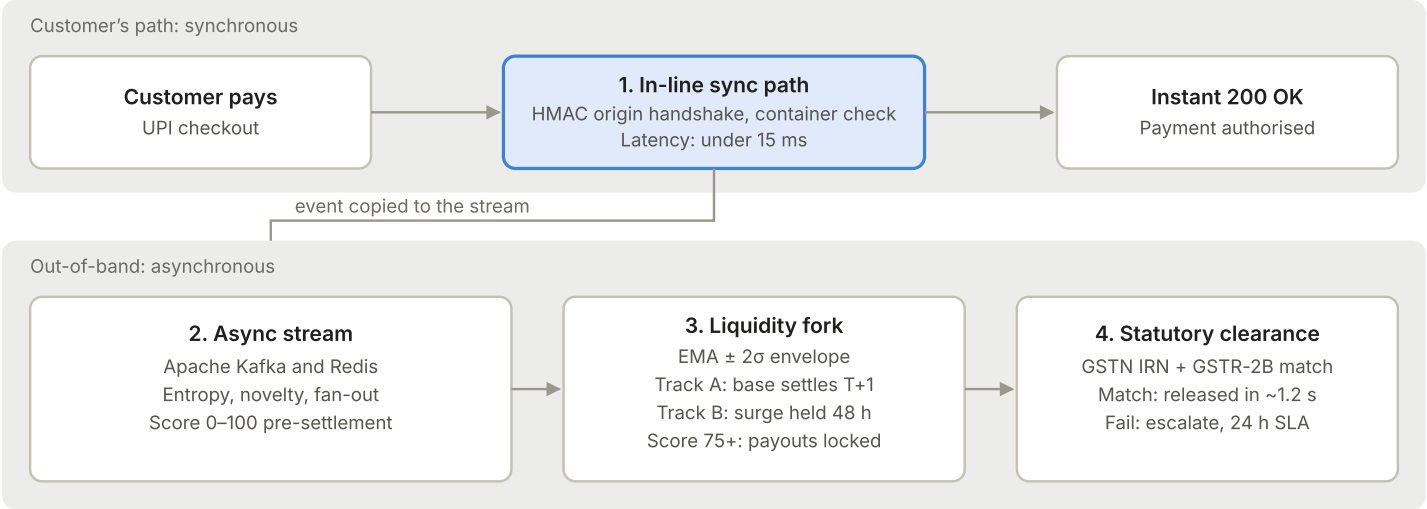
Party	Responsibility
Finshield engine (automated)	Scores every transaction, forks liquidity, runs the GSTN match, writes the audit log
Merchant	Keeps GSTN credentials linked; completes the one-click sync or Video KYC when prompted
Senior Risk Desk	Reviews failed matches within the 24-hour SLA and decides KYC outcomes and escalations
Compliance	Prepares and files the STR with FIU-IND and owns regulatory reporting

5. Part B: Process flow

5.1 Two rails, so checkout never waits

Checkout authorisation and deep forensics run on separate rails. Only a cryptographic handshake sits in the customer's path; everything heavier runs out-of-band.

Only the HMAC handshake sits in the customer's path



Finshield pipeline · 4 stages on 2 rails

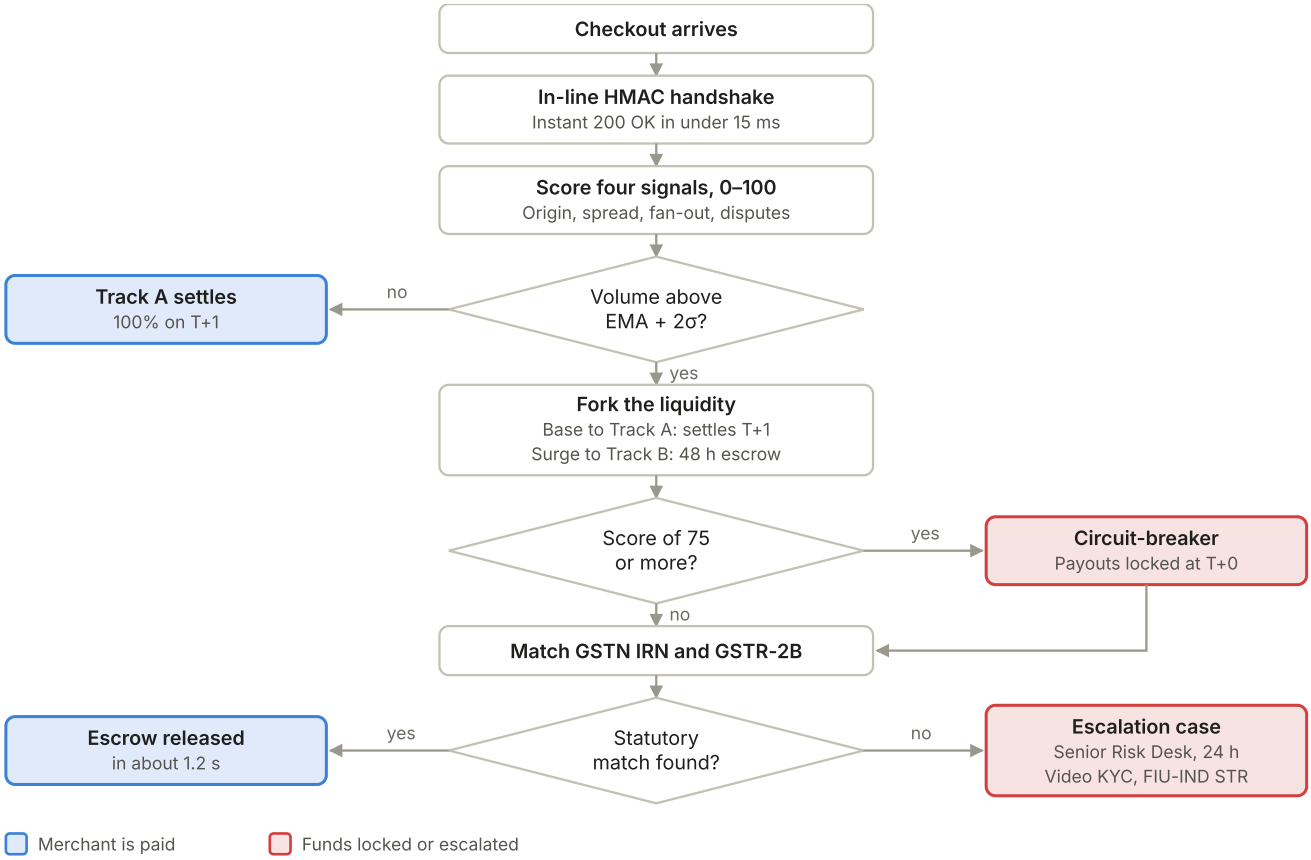
Stage 1 is the only step the customer waits for. Stages 2 to 4 run beside checkout, so genuine UPI conversion is untouched.

Stage	What happens	Technology	Output
1. In-line sync path	The SDK completes the HMAC origin handshake and container check	Checkout SDK	Instant 200 OK in under 15 ms
2. Out-of-band async stream	Entropy, VPA novelty and payout fan-out are computed in real time	Apache Kafka and Redis	Composite score 0–100 ahead of settlement batching
3. Pre-settlement liquidity fork	Volume above EMA + 2σ goes to the 48-hour escrow. A score of 75 or more also engages the payout circuit-breaker	EMA ± 2σ envelope	Track A and Track B split
4. Statutory clearance loop	IRN and GSTR-2B are matched. A match releases escrow; a failure escalates	GSTN e-invoice via GSP APIs	Release in about 1.2 s, or a case on the RBI compliance path

5.2 End-to-end decision flow

The flowchart shows the path of a single checkout and of the day's volume through the engine.

The base always settles; only the surge waits for statutory proof



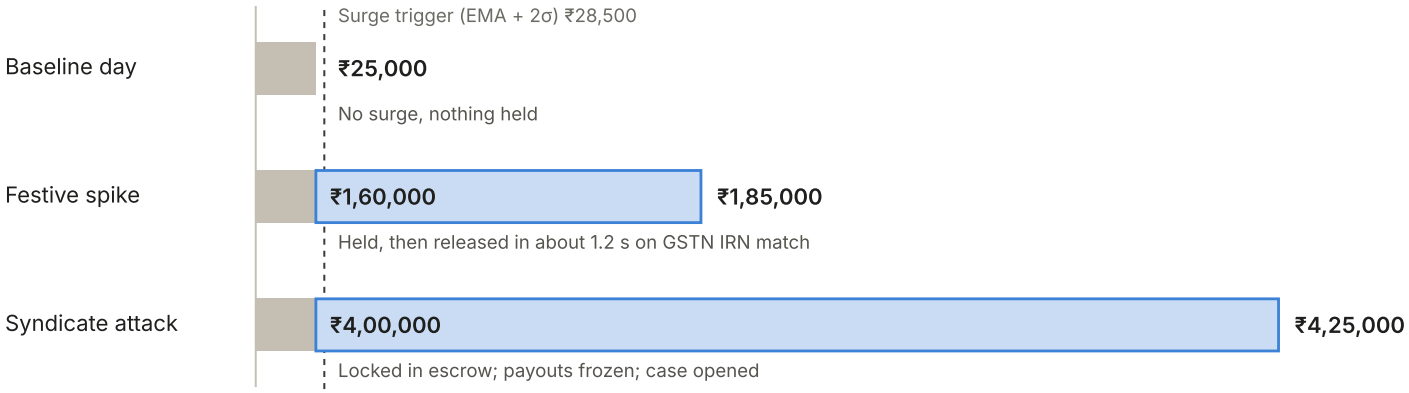
decision flow · 3 decisions. A clean day goes straight to Track A. A surge is forked, and the statutory match decides whether the escrow is released or escalated.

5.3 What the fork does to the money

The base always settles. Only the surge changes route, and what happens to it depends on the evidence.

Track A holds at ₹25,000 in every scenario; only Track B grows with the surge

Inflow by route, reference merchant, in rupees



prototype scenarios · baseline, festive, attack. The protected base settles in every scenario. Only the surge is held, and it clears or escalates on the GSTN match.

5.4 Verification across the five test cases

Case	Inflow	Score	Origin	H	Fan-out · disputes	Outcome
1. Baseline day	₹25,000	12	dailycrumb.in (HMAC valid)	0.19	1 : 2 · 0.03%	₹25,000 settled T+1 on Track A
2. Syndicate attack	₹4,25,000	91	t.me/bet_bot, aviator99.club (no HMAC)	0.96	1 : 214 · 4.82%	₹25,000 T+1; ₹4,00,000 frozen in escrow; payouts locked
3. Festive spike	₹1,85,000	34	dailycrumb.in and Swiggy POS (HMAC valid)	0.31	1 : 4 · 0.12%	₹25,000 T+1; ₹1,60,000 released in about 1.2 s on GSTN IRN match
Sandbox A: Pay ₹500	+₹500	12	dailycrumb.in, 10.4 ms	0.19 (local, Bengaluru)	Unchanged	Routed to Track A, T+1
Sandbox B: Bet ₹1,500	+₹1,500	86+	aviator99.club APK, 11.8 ms	Out-of-state VPA	Fan-out rises above 214	Held in Track B; Track A untouched

5.5 Three-minute demo script for the prototype

1. Open the console on Scenario 1, Baseline Day. The score is 12 and all ₹25,000 sits on Track A.
2. In the sandbox, click **Inject ₹500 Order**. It routes to Track A with a handshake of about 10 ms.
3. Click **Inject ₹1,500 Bet**. The score jumps, the origin alert fires and the bet lands in Track B while Track A is untouched.
4. Switch to Scenario 2, Syndicate Attack (score 91). Click **Run Real-Time GSTN Match** and watch the audit fail and Case #FIN-8942-RG route to the Senior Risk Desk.
5. Switch to Scenario 3, Festive Spike (score 34). Run the GSTN match and watch ₹1,60,000 release from escrow.
6. Open Tab 2 to show the four models: EMA envelope, payout fan-out, spatial entropy and dispute velocity.

6. Part C: Business model

6.1 Protecting the MDR margin

Payment aggregators earn a net merchant discount rate (MDR) of roughly 0.5% to 1.5% on processed volume. Legacy compliance erodes that margin twice: false-positive freezes lose legitimate festive volume and push merchants to rival gateways, and manual reviewers spend about ₹45 per flagged case on PDF invoices that are easy to forge.

Metric	Legacy rules and manual audit	Finshield v5.0	Impact for PayU
False-positive merchant churn	High: whole account frozen in festive spikes	Near zero: base settles T+1, surge clears in about 1.2 s	Keeps the 0.5%–1.5% MDR on seasonal MSME volume
Checkout latency	150–400 ms of synchronous rules	Under 15 ms	Protects UPI conversion
Statutory audit cost	About ₹45 per case, 24–72 hours	About ₹1.50 per automated GSTN pull	Over 95% lower compliance spend
Baseline telemetry cost	External fingerprint and IP-lookup fees	About ₹0, in-house Kafka and Redis	Scales across millions of daily UPI transactions
NPCI 1.0% chargeback exposure	Unbuffered: bettors withdraw before disputes land	T+0 escrow and 1 : 214 payout circuit-breaker	Guards against NPCI penalties and sponsor-bank holds

6.2 A tiered design keeps cost near zero

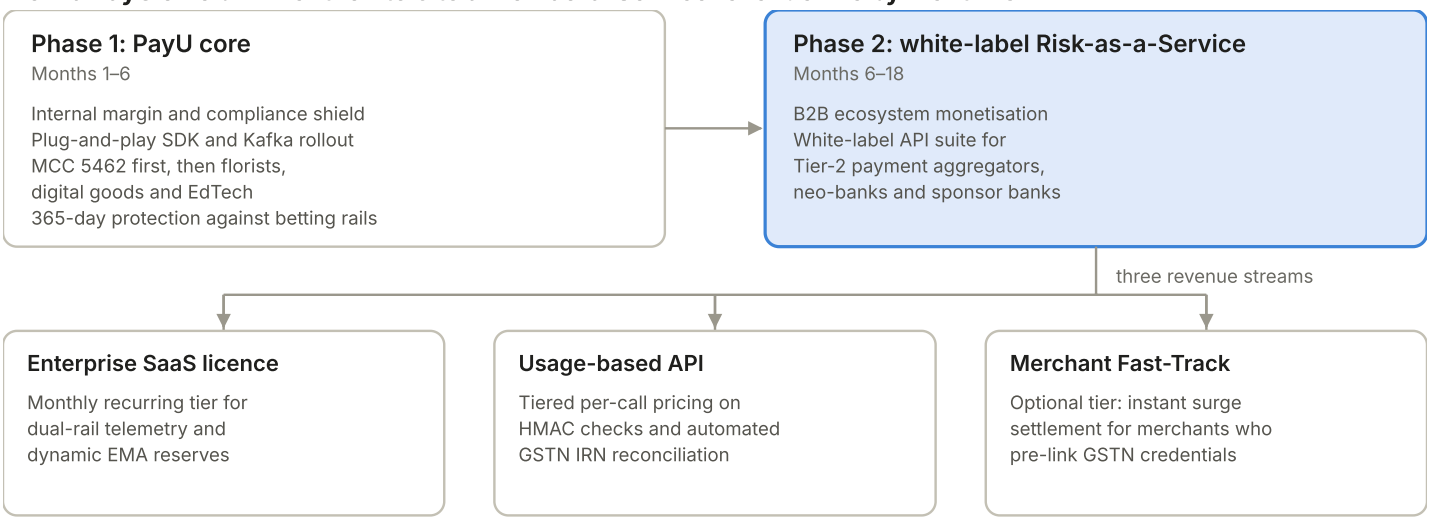
Layer	Runs on	External cost	When it runs
HMAC origin binding	Internal SDK	About ₹0	Every checkout
Kafka and Redis signals	Internal stream	About ₹0	Every transaction
GSTN pull via GSP	External API	About ₹1.50 per call	Only when inflow breaches EMA + 2σ, about 2% of events

Cost per flagged case falls from about ₹45 to about ₹1.50, a reduction of roughly 97%. Track B escrow also works as a self-funded buffer: the quarantined surge is intended to absorb a gambler chargeback wave without touching PayU's own balance sheet.

6.3 Two-phase go-to-market

Phase 1 proves the engine inside PayU. Phase 2 sells the same engine to the wider ecosystem through three revenue streams.

From a PayU shield in months 1 to 6 to a Risk-as-a-Service revenue line by month 18



go-to-market · 2 phases, 3 revenue streams

6.4 Revenue streams in Phase 2

Stream	What the customer buys	How it is charged	Typical buyer
Enterprise SaaS licence	Real-time dual-rail telemetry and dynamic EMA reserve management	Monthly recurring tier	Tier-2 payment aggregators, neo-banks
Usage-based API	HMAC session verification and automated GSTN IRN reconciliation	Tiered per-call pricing	Tier-2 aggregators, sponsor banks
Verified Merchant Fast-Track	Instant surge settlement for merchants who pre-link GSTN e-invoice credentials	Optional paid tier, price to be set	Seasonal MSMEs

6.5 Who benefits

Stakeholder	Gain
Merchant	Base settles T+1 even under attack; festive surges clear in about 1.2 s; no PDF paperwork
PayU	Preserved MDR margin, over 95% lower audit cost, under 15 ms overhead, a shield against NPCI and RBI penalties
Sponsor banks and regulators	An auditable T+0 trail, a defined escalation path and STR-ready cases
Payments ecosystem	A ready-made, white-label risk API

7. Assumptions, risks and pilot approach

The figures in this dossier come from the prototype's reference scenarios. They demonstrate the logic; they are not production measurements. Stating this openly shows reviewers what is proven and what remains to be calibrated.

Risk or assumption	How the design handles it
Thresholds (EMA window, 2σ multiplier, tier cut-offs, dispute bands) are reference values	Recommended: run in shadow mode on historical MCC 5462 data and calibrate before enforcing
A syndicate keeps volume just under the 2σ line	The other signals do not depend on volume: origin, geographic spread and payout fan-out still fire
A genuine surge has no matching e-invoice	Proposed: fall back to Level-2 Video KYC and Senior Risk Desk review within the 24-hour SLA, not automatic rejection
Holding merchant funds in escrow	Legal and sponsor-bank review of settlement and escrow treatment before launch; the hold is limited to 48 hours
GSTN dependency and per-call cost	Called only on the roughly 2% of surge events; proposed fallback to the Amber path if the GSP is unavailable
Prototype data is simulated	Live GSP, Kafka and Redis integration is the Phase 1 engineering scope

8. Final conclusion

A merchant ID that carries both a genuine bakery and a betting syndicate cannot be handled by a freeze: freezing bankrupts a real MSME, and ignoring the traffic exposes PayU to RBI and NPCI action. Finshield v5.0 resolves this by acting on liquidity, not on the account. The protected base (₹25,000 in the reference case) always settles on T+1 in Track A. Only the surge above EMA30D + 2σ (₹28,500) goes into a 48-hour Track B escrow, released on a programmatic GSTN IRN and GSTR-2B match, never on a PDF invoice.

Four independent signals (HMAC origin, spatial entropy and payer novelty, payout fan-out, and dispute velocity) close the four legacy blind spots and produce one 0–100 score before settlement. In the prototype the three scenarios land in different tiers: the baseline day scores 12, the festive spike scores 34 and releases ₹1,60,000 in about 1.2 s, and the syndicate attack scores 91, locking ₹4,00,000, freezing payouts and opening Case #FIN-8942-RG with an STR prepared, while the bakery's ₹25,000 still settles.

For PayU, the design keeps checkout overhead under 15 ms, cuts statutory audit cost from about ₹45 to about ₹1.50 per case, protects the 0.5%–1.5% MDR on seasonal MSME volume and gives sponsor banks and regulators an auditable T+0 trail. In Phase 2 the same engine can be sold as white-label Risk-as-a-Service through three revenue streams.

What is proven and what comes next. The figures come from simulated reference scenarios; they demonstrate the logic and are not production measurements. Before enforcement, the recommended path is shadow-mode calibration on historical MCC 5462 data, legal and sponsor-bank review of the escrow treatment, and live GSP, Kafka and Redis integration as the Phase 1 engineering scope.